



Supplier Agreement Management (SAM)

SAM Overview

Required PA Information

Intent

Selects qualified suppliers, establishes agreements, and manages the resulting supplier and acquirer activities over the term of the agreement.

Value

Maximizes the probability of mutual success for acquirers and suppliers.

Additional Required PA Information

If Data is included in the selected view: Identify data-related considerations, e.g., privacy, data quality, to be included in the supplier agreement.

If Safety is included in the selected view: Identify hazard and safety-related considerations, e.g., functional safety, to be included in the supplier agreement.

If Security is included in the selected view: Identify security-related considerations, e.g., physical security, database and information access, background checks, personnel clearances, to be included in the supplier agreement.

Explanatory PA Information

Practice Summary

Level 1

- SAM 1.1 Identify, evaluate, and select suppliers.
- SAM 1.2 Develop and record the supplier agreement.
- SAM 1.3 Accept or reject the supplier deliverables.
- SAM 1.4 Process supplier invoices.

Level 2

- SAM 2.1 Identify evaluation criteria, potential suppliers, and distribute supplier requests.
- SAM 2.2 Evaluate supplier responses according to recorded evaluation criteria and select suppliers.
- SAM 2.3 Manage supplier activities as specified in the supplier agreement and keep agreement updated.
- SAM 2.4 Verify that the supplier agreement is satisfied before accepting the acquired supplier deliverable.

SAM 2.5 Manage invoices submitted by the supplier according to the supplier agreements.

Level 3

SAM 3.1 Conduct technical reviews of supplier performance activities and selected deliverables.

SAM 3.2 Manage supplier performance and processes based on criteria in the supplier agreement.

Level 4

SAM 4.1 Select measures and apply analytical techniques to quantitatively manage suppliers against their performance targets.

Additional PA Explanatory Information

Supplier management activities involve:

- Selecting qualified suppliers
- Establishing the supplier agreement
- Implementing the supplier agreement
- Monitoring supplier technical activities
- Monitoring supplier processes and performance
- Accepting the delivery of acquired products
- Managing supplier invoices

The supplier agreement provides a mutual understanding between the acquirer and supplier and serves as the basis for managing their relationship. The agreement defines the processes, roles, and responsibilities that allow the acquirer to:

- Oversee the supplier's activities
- Monitor evolving supplier deliverables
- Verify compliance with supplier agreement requirements
- Resolve issues as necessary

The term "supplier deliverable" refers to an item to be provided to an acquirer or other recipient as specified in an agreement. The deliverable can be a document, hardware, software, services, or any type of solution or work product.

When the supplier's performance, processes, or supplier deliverables fail to satisfy established criteria as outlined in the supplier agreement, the acquirer takes corrective action. The acquirer must be aware of the legal implications of actions when managing the acquisition of supplier deliverables.

When monitoring supplier technical activities, the acquirer:

- Performs technical reviews of the supplier's technical deliverable
- Analyzes the development and implementation of the supplier's technical deliverable to confirm technical progress and satisfaction of contractual requirements

Typically, these activities interactively support one another to gauge technical progress and allow effective management of technical risks. Perform different levels of detailed analysis for technical reviews to meet the acquirer's requirements. Technical reviews with the supplier involve measuring technical progress and the effectiveness of plans and requirements. Technical reviews of the supplier should be performed with relevant processes, such as requirements management, risk and opportunity management, configuration management, and data management.

In some acquisitions, the acquirer assumes the role of overall architect or integrator for the supplier deliverable. The acquirer needs to ensure that changes to requirements and supplier agreements are acceptable given the constraints of the acquisition.

Related Practice Areas

Enabling Safety (ESAF)

Enabling Security (ESEC)

Managing Security Threats and Vulnerabilities (MST)

Context Specific

Security

Context Tag:	CMMI-SEC
Context:	Use processes to incorporate security considerations as an integral part of the solution, work, project, and organization.

Consider the following when managing agreements with suppliers:

- Focus on brand integrity rather than brand protection; this supports solution lifecycle threat modeling which proactively identifies and addresses supply chain vulnerabilities
- Use periodic supplier meetings to ensure suppliers understand the customers' and end users' business needs, concerns, and security priorities
- Provide mentoring and training programs to suppliers on key organizational security objectives and programs
- Identify and monitor security risks, threats, and vulnerabilities that may be introduced by including supplier solutions or third-party components into the solution
- Use supplier reviews and audits to help determine whether primary suppliers have security methods, standards, and safeguards in place; and a practice for vetting subordinate suppliers, for example, second- and third-tier suppliers and subcontractors
- Employ on-site security verification and validation of supplier self-evaluation reviews
- Software or Sales Bill of Materials (SBOM), also known as a Software Bill of Sales (SBOS), including open-source software or any other potential vulnerabilities present in the solution

Level 1

SAM 1.1

Required Practice Information

Practice Statement

Identify, evaluate, and select suppliers.

Value

Increases likelihood of selecting suppliers that meet the project's parameters.

Additional Required Information

This section left blank for future content.

Explanatory Practice Information

Additional Explanatory Information

This section left blank for future content.

Example Activities

Example Activities	Further Explanation
Identify potential suppliers and distribute requests for proposals.	Requests for Proposals (RFPs) may include: • Requirements ○ Technical ○ Non-technical ○ Contractual ○ Regulatory • List of deliverables • Time constraints • Cost estimates • Other identified proposal criteria
Evaluate proposals and select suppliers.	Leverage the criteria from the RFP to evaluate the proposals.

Example Work Products

Example Work Products	Further Explanation
List of potential suppliers	
RFP	
Proposal evaluation	

SAM 1.2

Required Practice Information

Practice Statement

Develop and record the supplier agreement.

Value

Increases likelihood of meeting requirements when using suppliers.

Additional Required Information

This section left blank for future content.

Explanatory Practice Information

Additional Explanatory Information

A supplier agreement is any recorded agreement between the acquirer and the supplier. Agreements can take a variety of forms, and may include:

- Contracts (or subcontract)
- Licenses
- Service agreements
- Service level agreements
- Memoranda of agreement
- Memoranda of understanding
- Letters of understanding
- Electronic acknowledgements of terms and conditions
- A combination of any of the above or other similar forms

The agreement can be either a stand-alone agreement or part of a master agreement. When part of a master agreement, the work agreement can be an addendum, work order, or service request to the master agreement.

Example Activities

Example Activities	Further Explanation
Develop and record a supplier agreement.	
Negotiate the terms of the candidate agreement with the supplier.	Negotiation may require updates to the supplier agreement.
Reach agreement with supplier.	

Example Work Products

Example Work Products	Further Explanation
Supplier Agreement	May include:

Example Work Products	Further Explanation
	• Affected stakeholders and communication involved • Statement of Work • Specifications • Terms and conditions • List of deliverables • Schedule • Budget • Legal or regulatory information

SAM 1.3

Required Practice Information

Practice Statement

Accept or reject the supplier deliverables.

Value

Increases the likelihood the supplier provides the agreed-on supplier deliverable.

Additional Required Information

This section left blank for future content.

Explanatory Practice Information

Additional Explanatory Information

The acquirer should ensure that the acquired supplier deliverable meets all agreed-on contractual requirements. The acquirer then decides whether to accept or reject the supplier deliverable.

Example Activities

Example Activities	Further Explanation
Accept or reject the supplier deliverable based on the extent that the agreed-on supplier deliverable meets contractual requirements.	

Example Work Products

Example Work Products	Further Explanation
Deliverables per the supplier agreement	

SAM 1.4

Required Practice Information

Practice Statement

Process supplier invoices.

Value

Maintains a good working relationship with suppliers while meeting agreements.

Additional Required Information

This section left blank for future content.

Explanatory Practice Information

Additional Explanatory Information

Processing supplier invoices may include:

- Paying the invoice, e.g., check, money order, credit card, electronic transfer of funds to supplier
- Trading goods or services
- Rejecting the invoice for revision
- Acknowledging the agreement has been met

A specific function, e.g., contracting office, accounts payable, or purchasing department, may process invoices.

Example Activities

Example Activities	Further Explanation
Process supplier invoices in accordance with agreements.	

Example Work Products

Example Work Products	Further Explanation
Records of supplier invoices	

Level 2

SAM 2.1

Required Practice Information

Practice Statement

Identify evaluation criteria, potential suppliers, and distribute supplier requests.

Value

Increases likelihood that selected suppliers consistently contribute to meeting business objectives.

Additional Required Information

This section left blank for future content.

Explanatory Practice Information

Additional Explanatory Information

The acquirer may use different types of acquisitions to guide supplier selection based on technical, regulatory, or customer requirements. Examples of acquisition types may include sole source, competitive bid, and joint venture. Potential suppliers are identified based on their capabilities and through mechanisms such as Requests for Information (RFI) and market research which can then lead into a Request for Proposal (RFP). RFIs and RFPs are examples of supplier request packages. The term supplier requests can represent requests from the acquirer to the supplier or from the supplier to the acquirer.

Frequently, acquirers use a competitive bid process for selecting suppliers, based on evaluation criteria that are shared with potential suppliers. Potential suppliers are identified through various means based on their capabilities.

The acquirer identifies potential suppliers to receive the RFP. Acquirers may request proposals from a limited number of suppliers to reduce the cost and effort for the solicitation. Acquirers should ensure they include suppliers who can meet the requirements and enough suppliers to provide a competitive environment.

Supplier selection criteria should address factors that are important to the work. These may include:

- Total lifecycle cost
- Supplier's geographical location
- Engineering capabilities
- People and facilities available to perform the work
- Prior experience in similar situations
- Supplier's past performance on similar work
- Customer satisfaction with similar solutions delivered by the supplier
- Warranties and maintainability

Example Activities

Example Activities	Further Explanation
Develop the Statement of Work (SOW) for the supplier.	The SOW typically includes: • An overview of the project, including objectives and description of the project environment and risks • Contractual and technical requirements, including Period of Performance (PoP); milestones; work location; legal, statutory, and regulatory requirements; delivery format; quantities; content requirements; solution acceptance criteria; required reviews and frequency; communication mechanisms; data management; data quality; security; safety • Supplier performance requirements and reporting including measures of quality, process, product, service levels, and transitions to operations and support • Design constraints • Deliverables, e.g., Work Breakdown Structure (WBS) or list of tasks for the supplier's work, detailed design, test results • Ownership, intellectual property, data, and proprietary rights • Additional services required related to the acquired solution, e.g., study reports, development of training materials, delivery of training to end users • Acquirer specified processes for the project, e.g., configuration management, quality assurance, issue escalation and resolution, corrective action for noncompliance, change management • Approach and responsibilities for quality reviews or audits • Proposal validity period The acquirer can revise and refine the SOW for the supplier as it moves through the solicitation, negotiation, and supplier agreement development processes until finally incorporating it into a signed supplier agreement.
Develop terms and conditions and additional information.	Terms and conditions may include: • Recitals or demonstrations of proposals • Compensation and payments • Confidentiality • Privacy or non-disclosure statements • Legal, regulatory, certification or other requirements • Exclusive services, key personnel, supplier personnel at acquirer sites • Ownership, intellectual property, data, and proprietary rights • Non-compete terms • Force majeure • Termination for insolvency, breach, non-performance, convenience, and any assistance terms • Term (length of the agreement) and renewal period • Indemnification and insurance • Right to audit

Example Activities	Further Explanation
	Additional information to help the supplier when responding to the supplier request package may include: • Submission of intent to submit proposal • Submission due date, time, and destination • Number of proposal response copies the supplier must submit • Proposal format • Non-complying proposals • Proposal ownership • Bidder inquiries • Key dates and activities • Discretionary selection and potential modifications of the solicitation process • Statements that: ○ The solicitation itself is not an implied contract ○ The response is not an obligation to do the work • Confidentiality of information • Publicity • Use of subcontractors • Due diligence • Incurred costs • Language requirements • Warranty and licensing provisions
Develop and record the required proposal contents.	Required proposal content requirements typically include: • Company overview, experience, and references • Evidence of the supplier's processes and quality management approach • Supplier solution description addressing requirements • Plan for supplier solution delivery, including risk and opportunity management, critical dependencies etc. • Supplier pricing methodology may include: ○ Calculation of charges, taxes, and credits ○ Foreign currency exchange rates ○ License fees ○ Pass-through costs ○ Travel reimbursements ○ Alignment to acquirer invoicing requirements • Compliance with legal, regulatory, certification or other requirements • Issue escalation and resolution approach • Information about intellectual property, data, and proprietary rights • Plan for retention of critical team members during the project

Example Activities	Further Explanation
	• Identification of work planned for further outsourcing to additional subcontractors
Develop proposal evaluation criteria.	The evaluation criteria used should be consistent with the requirements and complexity of the acquired solution. Evaluation criteria scales, measurements, and weighting should be incorporated in the supplier request package, as appropriate. Examples of criteria used to evaluate a potential supplier's ability and proposal include: • Response to all stated requirements contained in the supplier request package • Experience with similar solutions or services • Technical capability, including: ○ Technical methodologies and techniques ○ Solutions ○ Services ○ Systems, tools, networks, and technical compatibility requirements • Familiarity with acquirer processes, the technical environment, and the core business • Security and safety considerations • Total ownership and lifecycle costs • Supply chain reliability • Management, development, and delivery processes • Financial capability • Resource capacity, e.g., personnel available, facilities available • Business size and type • Intellectual property and proprietary rights • Compliance with regulatory requirements
Identify and finalize a list of qualified suppliers.	The acquirer may consider: • Suppliers and their personnel who have experience with similar systems or projects • Performance of suppliers on previous projects • Suppliers' financial capabilities, e.g., credit worthiness, financial stability, and access to capital
Communicate and review the supplier request package with affected stakeholders prior to distribution and obtain commitment.	Affected stakeholders may include potential suppliers and other industry representatives. Typical communication to suppliers includes: • Schedule for release of the supplier request package • Schedule for the return of proposals • Date when the supplier must indicate if they plan to respond to the supplier request package • Acknowledgement of receipt of proposal responses

Example Activities	Further Explanation
	Verify that all potential suppliers have equal access and opportunity to provide feedback on the supplier request package. Provide the opportunity for selected potential suppliers and stakeholders to clarify ambiguity and address concerns with requirements.
Manage supplier request package	Keep the package updated throughout supplier selection process. Communicate changes to the supplier request package or timeline to all affected stakeholders.

Example Work Products

Example Work Products	Further Explanation
Records of reviews of the supplier request package and stakeholder commitments	
Supplier and proposal evaluation criteria	
Supplier request package	Manage initial draft, and subsequent approved versions under configuration management.
List of qualified suppliers	
Communication records	May include: • Notifications to potential suppliers • Supplier submitted questions and requests for clarification • Acquirer responses to questions and requests

SAM 2.2

Required Practice Information

Practice Statement

Evaluate supplier responses according to recorded evaluation criteria and select suppliers.

Value

Matches selection of the best solution and supplier for meeting contractual requirements.

Additional Required Information

This section left blank for future content.

Explanatory Practice Information

Additional Explanatory Information

Evaluate proposals submitted in response to supplier request packages in accordance with a defined timeline. Use proposal evaluation criteria to evaluate potential supplier responses to the solicitation package. Score proposals against criteria and record evaluation results including decision-making notes, e.g., advantages and disadvantages of potential suppliers.

Use proposal evaluation results to finalize the supplier selection. In some cases, the acquirer can take the highest scoring proposals and uses negotiations to make the final selection decision.

Evaluation results and negotiation results support the selection decision or may cause the acquirer to take other actions as appropriate. If the return on investment (ROI) is not sufficient, the acquirer can decide to defer or cancel the solicitation.

Example Activities

Example Activities	Further Explanation
Verify conformance to requirements and completeness of supplier responses.	Contact the suppliers for corrective action if the response is non-conforming or incomplete.
Distribute supplier proposals to individuals performing the evaluation.	
Conduct initial review of supplier proposals.	Use this review to consolidate questions, concerns, and issues with the supplier proposals.
Schedule and hold supplier presentations.	Use presentations to ensure a mutual understanding of the SOW.
Evaluate and score supplier proposals according to evaluation criteria.	This may include an evaluation of past performance based on a review of: • Supplier's references • Any previous experience with the supplier • Prior performance on similar work • Supplier management capabilities • Personnel available to perform the work • Supply chain issues • Available facilities and resources • The project's ability to work with the proposed supplier This also includes evaluating the risks associated with each proposed supplier.
Perform due diligence on highest ranking suppliers.	Examples of typical due diligence activities include: • Reviews of proposed technical solutions and interfaces or connections for compatibility with acquirer systems and environment

Example Activities	Further Explanation
	• Reviews and validation of supplier references • Reviews of the operating environment's facilities and capabilities • Reviews of regulatory and security requirement performance • Reviews of supplier's capabilities • Reviews of cost and schedule estimates for the supplier's work
Negotiate with suppliers.	Negotiate with the candidate suppliers to resolve issues identified during due diligence and to address remaining issues with requirements. As appropriate, revise requirements that the supplier must fulfill.
Select a supplier.	Record the selection and rationale.

Example Work Products

Example Work Products	Further Explanation
Supplier proposal	
List of candidate suppliers	
Clarification correspondence between the acquirer and potential suppliers	
Evaluation results and rationale	May include: • Evaluation reports • Market studies • Trade studies • Evaluation criteria • Advantages and disadvantages of candidate suppliers • Results of due diligence
Revisions due to negotiations	
Supplier selection decision	

Related Practice Areas

Decision Analysis and Resolution (DAR)

Risk and Opportunity Management (RSK)

Context Specific

Security

Context Tag:	CMMI-SEC
Context:	Use processes to incorporate security considerations as an integral part of the solution, work, project, and organization.

The supplier selection team must evaluate and select suppliers, party components, or solutions according to an established security selection criteria process. Develop supplier selection and outsourcing processes jointly with input from Information Technology (IT), security, engineering, and operations personnel to ensure comprehensive coverage.

Typical criteria that are found in a security selection process include:

- Information security management system, e.g., information security policies, data protection, physical access, security incident handling processes, security tools and environment
- Due diligence and background checks to determine if there are any risks associated with implementing a supplier agreement
- Analysis of supplier processes used to build, operate, and support solutions, information systems, solution components, and information system services
- Assessment of supplier training and experience in developing and delivering solutions, solution components, or services with the required security capability. These reviews provide organizations with increased levels of visibility into supplier activities during the solution lifecycle to promote more effective supply chain risk and opportunity management.
- Testing of supplier capabilities, e.g., through a pilot or prototype
- Supplier reviews to determine whether primary suppliers have security safeguards in place and a practice for vetting subordinate suppliers, for example, second- and third-tier suppliers and subcontractors. Questions that should be considered for the selection process include:
 - How do the suppliers manage their own personnel? Consider personnel in supplier companies that have access to the data, systems, or facilities of their customers.
 - How do the vendors manage their service providers? Any service provider with access to company information poses a potential cyber risk
 - How do the vendors manage their products and software? Consider solutions with embedded Information Technology (IT) and Application Programming Interface (API) that integrate into customer's systems

Consider possible introduction of threats and vulnerabilities based on acquisition types. For example, developed versus purchased solutions result in different security implications.

SAM 2.3

Required Practice Information

Practice Statement

Manage supplier activities as specified in the supplier agreement and keep agreement updated.

Value

Maximizes the likelihood that the supplier will fulfill acquirer expectations.

Additional Required Information

This section left blank for future content.

Explanatory Practice Information

Additional Explanatory Information

Monitor and update the supplier agreement based on the supplier selection decision and based on actual results.

The acquirer, supplier, and affected stakeholders should review agreement requirements to ensure that a common understanding is kept up-to-date through the life of the agreement. After establishing the supplier agreement, requirements may change, based on factors such as:

- Applicability of requirements
- Availability of new technology
- Reduction of overly burdensome reporting
- Organization changes, e.g., merger or acquisition
- Legal or regulatory changes
- Results from audits and other reviews

The supplier agreement and work documents should be revised to reflect changes in conditions. This includes updating cost, schedule, and budget as needed. Legal or contract advisors often are responsible for reviewing supplier agreements among independent legal entities prior to approval.

The content of the supplier agreement should specify how the agreement will be monitored and revised as required. This should be done in a way that is appropriate to the acquisition or supplier deliverable being acquired.

The acquirer monitors the supplier's progress against the agreement to identify and resolve issues. Monitoring includes internal and external communication as well as the use of information by the acquirer and supplier regarding the relationship, performance, results, and impact to the business. Agreement, management, technical, and other reviews may be conducted together or separately.

Example Activities

Example Activities	Further Explanation
Establish supplier agreement.	May include: • A description of required reporting data to allow the acquirer to evaluate and analyze acquired supplier deliverables • The acquirer and supplier representatives who are responsible and authorized to make changes to the supplier agreement • Planned reviews and interactions between the acquirer and supplier • The mechanism for how changes to the requirements and the supplier agreement are determined, communicated, and addressed • Applicable standards, procedures, tools, and methods • Critical dependencies between the acquirer and supplier • A list of what the acquirer provides to the supplier, e.g., facilities, access, tools, software, documentation, services • Analysis methods and acceptance criteria for designated supplier deliverables • The types of reviews to be conducted with the supplier • Payment or compensation terms and conditions • Non-hire and non-compete clauses • Confidentiality, non-disclosure, and intellectual capital clauses • The supplier's responsibilities for preparing the site and providing training The supplier's responsibilities for ongoing maintenance and support of acquired supplier deliverables.
Verify that the acquirer and supplier understand and agree to all requirements by approving the supplier agreement.	Approval may take different forms, such as: • Signature • Electronic approval or acknowledgement • Stamp or record of corporate/company approval • Other legally-binding acceptance
Monitor supplier progress and performance, e.g., schedule, effort, cost, technical, as defined in the supplier agreement.	Monitoring can be conducted during agreement, technical, and management reviews. Reviews can include both planned and as-needed interactions. Reviews cover both formal and informal reviews and include the following steps: • Preparing for the review • Ensuring that affected stakeholders participate • Conducting the review • Preparing, distributing, or making a summary report available to the affected stakeholders • Identifying issues and determining corrective actions necessary to resolve and track the issues to closure

Example Activities	Further Explanation
	Monitoring risks involving the supplier and mitigating them as necessary, e.g., supply chain issues
Conduct agreement reviews with the supplier as specified in the supplier agreement.	May include: - Agreement changes or updates - Stakeholder reassignment - Interpretation and clarification of terms, conditions, and deliverables - Positive or negative feedback on contractual requirements
Conduct technical reviews with the supplier as defined in the supplier agreement.	Technical reviews typically include: - Providing the supplier with visibility into the needs and preferences of the customers and end users as appropriate - Reviewing the supplier's technical activities and verifying that the supplier's interpretation and implementation of the requirements are consistent with the acquirer's interpretation - Ensuring that technical commitments are being met and that technical issues are communicated and resolved in a timely manner - Obtaining technical information about the supplier's deliverables - Providing appropriate technical information and support to the supplier
Conduct management reviews with the supplier as specified in the supplier agreement.	This typically includes reviewing: - Critical dependencies - Risks involving the supplier - Schedule and budget - The supplier's compliance with legal and regulatory requirements Unresolved issues escalate through the appropriate management chain according to a project's or organization's issue resolution process.
Record results of the reviews and interactions.	Use the results of reviews to improve the supplier's performance and to establish and nurture long-term relationships with preferred suppliers.
Manage the supplier agreement and keep it updated.	This typically includes: - Recording all changes formally approved by both the acquirer and supplier - Developing, recording, and keeping the requirements updated, e.g., supplier deliverable requirements, service level agreements - Periodically reviewing the supplier agreement to ensure it accurately reflects current plans, processes, risks, and market conditions

Example Activities	Further Explanation
	• Ensuring that the agreement, and data related to it, are stored and managed for future use • Performing impact assessments across technical and commercial aspects of the agreement • Assessing all alternatives associated with the change
Verify that the acquirer and supplier understand and agree to all changes to requirements by approving the updated supplier agreement.	Formal changes may be recorded as contract addenda for formal change requests.
Communicate changes to the supplier agreement with affected stakeholders.	Ensure that all affected stakeholders are aware of the agreement changes.

Example Work Products

Example Work Products	Further Explanation
Supplier agreement	
Formal change requests or contract addenda	
Records of communication, progress, review materials, and performance reports	May include: • Schedule • Budget information • Issue and action item list • Risk matrix • Meeting minutes • People assigned corrective actions • Deliverable status • Due date for actions

Related Practice Areas

Monitor and Control (MC)

Planning (PLAN)

Requirements Development and Management (RDM)

Context Specific

Security

Context Tag:	CMMI-SEC
Context:	Use processes to incorporate security considerations as an integral part of the solution, work, project, and organization.

Ensure that all activities identified in contracts contain standard security terms, conditions, and tailoring options that must be implemented to meet commitments in the supplier agreement.

Ensure the Statement of Work (SOW) addresses the following security related aspects:

- Security governance
- Manufacturing and operational security
- Software engineering and architecture
- Asset management
- Incident management
- Transportation security
- Physical and environmental security
- Personnel security
- Information protection
- Sub-tier supplier and partner security, e.g., service providers and cloud

Establish measurement objectives relevant to managing secure suppliers, including a focus on understanding the effects of supplier performance on security-related operational and financial performance. Measurement objectives for the supplier enable tracking of the security-related service-level expectations recorded in the supplier agreement. Collect supplier measurement data to provide information in support of managing security aspects of the supplier agreements.

Examples of measures to monitor security for suppliers include:

- Number of threats and vulnerabilities discovered in the supplier's solutions or solution components
- Types of threats and vulnerabilities discovered in the solutions or solution components
- Number of supplier work product security evaluations completed, planned versus actual
- Number of supplier security process evaluations completed, planned versus actual
- Number of security incidents, by category, severity, and impact in the supplier's solution or solution components

SAM 2.4

Required Practice Information

Practice Statement

Verify that the supplier agreement is satisfied before accepting the acquired supplier deliverable.

Value

Decreases risk of accepting an unsatisfactory supplier deliverable and confirms the supplier agreement is satisfied before acceptance.

Additional Required Information

The acquirer confirms that all recorded acceptance criteria have been satisfied and all issues affecting satisfaction of the agreement have been addressed.

Explanatory Practice Information

Additional Explanatory Information

Requirements for deliverable acceptance and how to address non-conforming deliverables are usually defined in the supplier agreement. The acquirer should be prepared to take appropriate action as per the agreement if the supplier fails to perform. This may include invoking any contractual penalties or conditions.

The acquirer provides the supplier with notice that supplier deliverables have been accepted or rejected.

Typically, an authorized representative of the acquirer assumes ownership of identified supplier deliverables as partial or complete satisfaction of the supplier agreement.

Acceptance reviews should be completed before accepting the supplier deliverables as defined in the supplier agreement. Once accepted, the acquirer monitors the transition of the supplier deliverables to the project or operations.

Example Activities

Example Activities	Further Explanation
Refine, update or add, and use acceptance criteria and procedures to verify that the supplier agreement is satisfied.	This activity is typically performed by the acquirer on the supplier deliverables.
Review and obtain agreement from affected stakeholders on the acceptance procedures before the acceptance review.	
Following acceptance criteria and procedures, verify that the acquired supplier deliverable satisfies the supplier agreement.	From the supplier, this may include review of supplier deliverable verification results, including: • Reports, logs, and issues • Testing results • Known errors or defects For the acquirer, this may include reviewing results of supplier-performed acceptance reviews and tests.
Confirm that all agreed-on contractual requirements for the acquired supplier deliverable are satisfied.	May include the following items that demonstrate that the agreed-on requirements have been met: • License • Warranty • Ownership • Usage • Support, service, or maintenance agreements

Example Activities	Further Explanation
	Other supporting materials, e.g., end-use, operations or support, and maintenance documentation
Communicate to affected stakeholders that the supplier agreement has been satisfied.	The acquirer provides the supplier with notice that the supplier agreement has been satisfied, including readiness for transition to operations and support, so the supplier can be paid, and the supplier agreement closed.

Example Work Products

Example Work Products	Further Explanation
Acceptance criteria and procedures	
Discrepancy reports or corrective action plans	
Acceptance review report with recorded approval	
Formal acceptance notifications	Notifications should be communicated to the supplier and affected stakeholders.
A record that all agreement requirements have been met	Approval may take different forms, such as through: - Signature - Electronic approval or acknowledgement - Stamp or record of corporate/company approval - Other legally-binding acceptance

Related Practice Areas

Monitor and Control (MC)

Planning (PLAN)

Verification and Validation (VV)

Context Specific

Safety

Context Tag:	CMMI-SAF
Context:	Use processes to incorporate safety considerations as an integral part of the solution, work, project, and organization.

Accept safety-related solutions and solution components and identify hazards that could arise from accepting and integrating the solution or solution component in the environment.

Methodologies to ensure what was requested is what was received include acceptance reviews, tests, verification and validation activities, configuration audits, and safety evaluations. Safety evaluations are a common and effective acceptance methodology, conducted to uncover hazards.

The supplier agreement specifies the acceptance criteria for work products, including parameters of safety evaluations and risk remediation processes.

Security

Context Tag:	CMMI-SEC
Context:	Use processes to incorporate security considerations as an integral part of the solution, work, project, and organization.

Accept security-related solutions and solution components and identify threats and vulnerabilities that could arise from accepting and integrating the solution or solution component in the environment.

Methodologies to ensure what was requested is what was received include acceptance reviews, tests, verification and validation activities, configuration audits, and security evaluations. Security evaluations are a common and effective acceptance methodology, conducted to uncover vulnerabilities, e.g., malicious code, malicious processes, defective software, and counterfeit components.

The supplier agreement specifies the acceptance criteria for work products, including parameters of security evaluations and flaw remediation processes.

SAM 2.5

Required Practice Information

Practice Statement

Manage invoices submitted by the supplier according to the supplier agreements.

Value

Maintains a good business relationship between the acquirer and supplier.

Additional Required Information

This section left blank for future content.

Explanatory Practice Information

Additional Explanatory Information

Ensure that payment terms defined in the supplier agreement are met and that processing of supplier compensation is linked to supplier progress and results, as defined in the supplier agreement. This includes invoices for any type of charge, e.g., one-time, monthly, deliverable-based, pass-through. It covers invoice errors or issues, changes to invoices, and withholding disputed charges consistent with the terms and conditions of the supplier agreement. The acquirer should also ensure that appropriate financial and invoice management controls are in place.

When accepting supplier deliverables, the acquirer should not process final payment to the supplier until all supplier deliverables meet contractual requirements and all acceptance criteria have been satisfied.

Example Activities

Example Activities	Further Explanation
Receive invoices.	
Review invoices and related supporting material with authorized representatives for accuracy.	Examples of areas of review for invoices and related support material include: • Variable charges • Applicable taxes • Purchases made by the supplier on behalf of the acquirer • Formal acceptance signoff from receiving project team or authorized representative
Resolve errors and manage issues with the supplier as required.	
Approve and pay invoices.	
Archive and store invoices and payment records.	

Example Work Products

Example Work Products	Further Explanation
Invoices reviewed and approved for payment	
Record or receipt of payment	Payment per the supplier agreement, e.g., check, money order, credit card, electronic transfer of funds to supplier
Archived invoice and payment records	

Related Practice Areas

Monitor and Control (MC)

Level 3

SAM 3.1

Required Practice Information

Practice Statement

Conduct technical reviews of supplier performance activities and selected deliverables.

Value

Improves the acquirer's confidence in the ability of the supplier to provide the right supplier deliverable at the right time with the right quality.

Additional Required Information

Technical reviews of supplier performance activities and selected deliverables are conducted using an organizational approach.

Explanatory Practice Information

Additional Explanatory Information

Technical reviews are used by the acquirer to confirm that supplier deliverables being developed or produced by suppliers meet requirements.

Technical reviews are conducted:

- When the technical supplier deliverable under development meets the criteria specified in the supplier agreement
- At the transition from one acquisition phase to the next and at major transition points of technical effort

The supplier is responsible for managing the requirements and interfaces or connections of the supplier deliverable it is developing. However, the acquirer identifies interfaces or connections that it manages as well, particularly external interfaces or connections.

The interfaces or connections being considered for selection should include other supplier deliverables in the operations, support, verification, and validation environments. The acquirer should review all supplier interface or connection data for completeness. Acquirer technical reviews should include reviews of the subcontractor's work and deliverables. In addition to interfaces or connections, the acquirer should consider the following criteria when selecting supplier deliverables for analysis and review:

- Performance
- Recovery
- Safety
- Security
- Specification tolerance limits
- Mean Time to Failure (MTTF)

- Mean Time Between Failure (MTBF)
- Maintainability
- Serviceability
- Updateability
- Modularity

Example Activities

Example Activities	Further Explanation
Develop criteria for determining which technical supplier deliverable to analyze.	
Identify technical supplier deliverables for analysis.	Technical supplier deliverables that are typically analyzed by the acquirer may include: • Supplier derived deliverable and component requirements, architectures, and designs • Deliverable interface or connection descriptions • Deliverables and deliverable components • Fit for purpose requirements
Identify the functional and quality attribute requirements to be satisfied by each selected technical supplier deliverable.	A traceability matrix is a useful tool for identifying requirements for each selected technical solution, as it typically includes information that relates requirements to work products. When identifying requirements for each selected technical supplier deliverable, consult the appropriate traceability matrix.
Identify the analysis methods to be used for each selected technical supplier deliverable.	Examples of techniques used for analysis include: • Simulations • Prototyping • Architecture evaluation • Demonstrations • Peer Reviews • Automated testing
Include analysis methods and review activities in the work plan.	
Confirm that the selected technical supplier deliverable adheres to applicable standards and criteria.	
Confirm that the selected technical supplier deliverable adheres to allocated functional and quality attribute requirements.	
Use analysis results to compare actual performance measurements	

Example Activities	Further Explanation
to specified thresholds of technical performance measures.	
Review critical verification results and data from verifications performed by the supplier.	
Identify interfaces or connections that are candidates for acquirer management.	Example criteria for interfaces or connections include: • Spans organizational boundaries • Mission critical • Difficult or complex to manage • Key quality attributes • Multiple acquisition projects
Review identified interfaces or connections against the selection criteria and include in the work plan.	
Confirm the compatibility of selected interfaces or connections throughout the life of the solution.	Confirm that interface or connection descriptions adhere to applicable standards, criteria, and connection requirements between the supplier's supplier deliverable and acquirer's intended environment.
Verify that interfaces or connections have been sufficiently tested by the supplier.	
Verify that issues identified during testing have been resolved appropriately, with deliverable revisions, if necessary.	
Resolve conflict, noncompliance, and change issues for the selected interfaces or connections.	

Example Work Products

Example Work Products	Further Explanation
Activity reports	
Discrepancy reports	
Criteria used to select technical supplier deliverables for analysis	
Lists of supplier requirements and technical supplier deliverables selected for analysis	

Example Work Products	Further Explanation
Analysis methods for each selected supplier deliverable	
Noncompliance and change logs	
Record of analysis results	May include: • Issue and action item list • Meeting minutes • People assigned corrective actions • Due date for actions
Criteria to be used in selecting acquirer managed interfaces or connections	

Related Practice Areas

Managing Performance and Measurement (MPM)

Requirements Development and Management (RDM)

Verification and Validation (VV)

Context Specific

Development

Context Tag:	CMMI-DEV
Context:	Use processes to develop quality products and services to meet the needs of customers and end users.

Perform technical reviews throughout the work lifecycle to gain confidence that the requirements, architecture, and technical supplier deliverables provide the required capability. These reviews should be integrated with risk and opportunity management activities.

Types of technical reviews that can be conducted include:

- Integrated Baseline Review (IBR)
- Technology Readiness Assessment (TRA)
- System Requirements Review (SRR)
- Preliminary Design Review (PDR)
- Critical Design Review (CDR)
- Test Readiness Review (TRR)
- Production Readiness Review (PRR)
- Operational Test Readiness Review (OTRR)

Depending on where in the acquisition lifecycle the highest risks occur, the acquirer selects technical supplier deliverables for analysis to reduce those risks. Select analysis methods based on the type of technical solution being analyzed and the nature of the risk. For example:

- In the design phases of the solution, quality attribute models, simulations, prototypes, or pilots can be used to provide additional information about the properties of the potential design solutions to aid in their evaluation and selection. Simulations can be particularly useful for complex systems.
- In the implementation phase, the acquirer can examine a supplier deliverable to determine if it is ready for production and if the supplier has accomplished adequate production planning. The analysis determines if production or production preparations pose unacceptable risks that might compromise cost, schedule, performance, or other established objectives. The acquirer might evaluate the full production configured supplier deliverable to determine if it correctly and completely implements all contractual requirements. The acquirer could also determine whether the traceability of the final contractual requirements to the final production configured solution has been kept updated.

The acquirer should select a supplier's design to analyze the adequacy and completeness of that design. The acquirer may also confirm that:

- The selected design adheres to applicable design standards and criteria
- The design adheres to allocated functional and quality attribute requirements
- The resulting supplier deliverable will perform appropriately in its target environment
- The solution baseline enables hardware fabrication and software coding to proceed with proper configuration management
- Adequate production processes and measures are in place for the work to succeed
- The design can be implemented within the production budget

During implementation, the supplier implements the design reviewed and analyzed by the acquirer by developing supplier deliverable components, integrating those components, performing unit and integration testing of the solution, and developing operational and end user documentation.

The acquirer can require delivery of verification results from the supplier of the technical solution, as applicable. The suppliers can perform verifications in an iterative fashion, concurrently with the acquirer's technical analyses, or the supplier can be required to perform follow-on verifications of technical solutions.

Typical expectations for verification addressed by the supplier agreement may include:

- List of deliverables and other work products that must be verified by the supplier
- Applicable standards, procedures, methods, and tools
- Criteria for verification of supplier work products
- Measurements to be collected and provided by the supplier regarding verification activities
- Reviews of supplier verification results and corrective actions with the acquirer

Examples of considerations for follow up verifications of technical solutions include if:

- During the production stage of the work, there are changes in either materials or manufacturing processes
- Production re-starts after a significant shutdown period
- Production starts up with a new supplier
- A manufacturing site has relocated

The acquirer can determine if the supplier's implementation is successful by analyzing if the:

- Supplier deliverable is ready to be brought into the acquirer environment for further integration and acceptance testing
- Production capability is satisfactory enough to perform pilot studies or move to full-rate production
- Requirements are fully met in the final production configuration

The acquirer should also confirm that sufficient end user documentation has been developed and is aligned with the tested implementation. The supplier can develop preliminary versions of the installation, operations, and maintenance documentation in early phases of the work lifecycle for review by the acquirer and affected stakeholders.

SAM 3.2

Required Practice Information

Practice Statement

Manage supplier performance and processes based on criteria in the supplier agreement.

Value

Maximizes the probability that supplier's performance will meet acquirer's needs, while minimizing risk.

Additional Required Information

An organizational approach for selecting and managing supplier processes and deliverables is in place and followed.

Explanatory Practice Information

Additional Explanatory Information

When close alignment between supplier and acquirer processes is critical to the success of the project, the acquirer should manage these processes to help prevent problems.

Selecting processes for managing involves considering the impact of the supplier's processes on the project. On larger projects with significant subcontracts with critical supplier deliverables or solution components, managing key processes may be needed.

The acquirer decides on the necessary level of managing depending on the level of risk incurred when the supplier's process is not performed correctly. Managing processes can range from reviewing supplier performance data to conducting on-site appraisals of the supplier's processes. Analyzing selected processes involves compiling and analyzing supplier process data to determine whether there are serious risks or issues.

Example Activities

Example Activities	Further Explanation
Select and manage processes used by the supplier as defined in the supplier agreement.	Supplier processes that are critical to the success of the project should be managed. When selecting processes to manage, consider the impact on the supplier.
Analyze processes used by the supplier as defined in the supplier agreement and communicate with affected stakeholders.	Analyze results of managing selected processes to detect issues as early as possible that may affect the supplier's ability to satisfy requirements of the supplier agreement. Trend analysis may be performed and can rely on internal and external data.

Example Work Products

Example Work Products	Further Explanation
List of processes selected for managing and rationale for selection	
Reports from managing	May include: • Supplier performance reports • Discrepancy reports • Action items and risks • Data quality assessment results • Data management assessment results
Record results of analysis	

Related Practice Areas

Causal Analysis and Resolution (CAR)

Managing Performance and Measurement (MPM)

Monitor and Control (MC)

Level 4

SAM 4.1

Required Practice Information

Practice Statement

Select measures and apply analytical techniques to quantitatively manage suppliers against their performance targets.

Value

Enhances supplier performance by focusing attention on the most critical areas for success.

Additional Required Information

Supplier performance requirements are shared with the supplier as part of the supplier agreement. These supplier performance targets are quantitatively managed throughout the life of the agreement.

The acquirer must statistically or quantitatively manage their own internal processes or the supplier processes and solutions in conjunction with the supplier when the Quality and Process Performance Objective (QPPO) requires it.

Explanatory Practice Information

Additional Explanatory Information

In situations where the supplier's related critical processes, solutions or components impact the acquirer's business objectives or impact the acquirer's delivered solution, product or service, the acquirer establishes QPPOs for their own internal processes or the supplier's, or both.

Appropriate analytical techniques can enable the acquirer to recognize significant deviations from performance objectives specified in the supplier agreement. This enables the acquirer to identify areas for potential corrective action with suppliers, and focuses attention on the most important elements of supplier performance.

Example Activities

Example Activities	Further Explanation
Identify key acquirer QPPOs for targeted supplier processes and deliverables.	
Establish a performance measurement specification to monitor supplier progress and performance using quantitative or statistical techniques.	This should be included in the supplier agreement and be traceable to the acquirer's QPPOs. Trace key measures to the performance measurement specifications and the QPPOs. Selection should not be limited to supplier deliverable, progress, or performance measures only. Measures can

Example Activities	Further Explanation
	be used to develop analysis, process, and success indicators which provide better insight into supplier performance. Identify any data quality requirements.
Collect data from the supplier and perform the analysis.	
Record results of analysis and communicate with stakeholders.	
Identify corrective action with the supplier.	
Monitor corrective action to closure.	

Example Work Products

Example Work Products	Further Explanation
Supplier-related performance measurement specifications	
List of selected supplier-related measures	Measures may include: • Operational definitions suitable to support statistical and other quantitative management • Identified statistical and other quantitative techniques to analyze the measures • Representations of data and analysis results • Identified key performance objectives • Supplier process data
Results of the analyses against their targets	Trace to objectives as defined in the supplier agreement.
Action item list	Include corrective actions and status.

Related Practice Areas

Causal Analysis and Resolution (CAR)

Managing Performance and Measurement (MPM)

Planning (PLAN)

